

Spring Security Roadmap

Module 1: Security Fundamentals

1. What is Security?
 2. Authentication vs Authorization
 3. Confidentiality, Integrity, Availability (CIA Triad)
 4. Common Web Security Attacks
 - CSRF
 - XSS
 - SQL Injection
 - Session Fixation
 - Clickjacking
 - CORS
 5. OWASP Top 10 Overview
-

Module 2: Spring Security Basics

1. Introduction to Spring Security
2. Spring Security Architecture
3. Default Login Mechanism
4. Security Filter Chain
5. How Request Processing Works
6. SecurityContext
7. SecurityContextHolder
8. Authentication Object
9. GrantedAuthority
10. Principal
11. UserDetails
12. UserDetailsService

13. UserDetailsManager
 14. PasswordEncoder
 15. BCryptPasswordEncoder
-

Module 3: Authentication

1. Username & Password Authentication
 2. Form-Based Authentication
 3. HTTP Basic Authentication
 4. Digest Authentication (Concept)
 5. Custom Authentication
 6. AuthenticationManager
 7. AuthenticationProvider
 8. DaoAuthenticationProvider
 9. AuthenticationEntryPoint
 10. Custom Login Page
-

Module 4: Authorization

1. Role-Based Authorization
2. Authority-Based Authorization
3. hasRole()
4. hasAuthority()
5. hasAnyRole()
6. hasAnyAuthority()
7. URL-Level Authorization
8. Method-Level Authorization
9. @PreAuthorize
10. @PostAuthorize
11. @Secured

12. @RolesAllowed

Module 5: Password Security

1. BCrypt
 2. Password Hashing
 3. Password Salting
 4. DelegatingPasswordEncoder
 5. Password Upgrade Strategy
-

Module 6: Session Management

1. What is Session?
 2. Stateful Authentication
 3. Session Management
 4. Session Timeout
 5. Concurrent Sessions
 6. Session Fixation Protection
 7. Remember Me Authentication
-

Module 7: CSRF Protection

1. What is CSRF?
 2. CSRF Attack Flow
 3. CSRF Token
 4. SameSite Cookies
 5. Origin Validation
 6. Spring Security CSRF
 7. Disabling CSRF
 8. CSRF with JWT
-

Module 8: JWT Authentication

1. What is JWT?
 2. JWT Structure
 3. Header
 4. Payload
 5. Signature
 6. Access Token
 7. Refresh Token
 8. JWT Authentication Flow
 9. JWT Validation
 10. JWT Expiration
 11. JWT Claims
 12. JWT Signing Algorithms
 13. HS256
 14. RS256
 15. Secret Key vs Public/Private Key
-

Module 9: Stateless Security

1. Stateless Authentication
 2. SessionCreationPolicy
 3. STATELESS
 4. NEVER
 5. IF_REQUIRED
 6. ALWAYS
 7. SecurityContext in Stateless Applications
-

Module 10: Filters

1. What is a Filter?

2. Servlet Filters
 3. Filter Chain
 4. Spring Security Filter Chain
 5. OncePerRequestFilter
 6. Custom JWT Filter
 7. Filter Ordering
 8. Filter Registration
-

Module 11: Exception Handling

1. AuthenticationException
 2. AccessDeniedException
 3. AuthenticationEntryPoint
 4. AccessDeniedHandler
 5. Custom Error Responses
-

Module 12: OAuth 2.0

1. OAuth 2.0 Basics
 2. Authorization Server
 3. Resource Server
 4. Client
 5. Authorization Code Flow
 6. Client Credentials Flow
 7. Refresh Token Flow
 8. PKCE
 9. OpenID Connect (OIDC)
-

Module 13: CORS

1. What is CORS?

2. Same-Origin Policy
 3. Preflight Request
 4. OPTIONS Request
 5. CORS Configuration in Spring Security
-

Module 14: Advanced Spring Security

1. SecurityContextHolder Strategy
 2. ThreadLocal Security Context
 3. Async Security
 4. SecurityContextPropagation
 5. Multiple Authentication Providers
 6. Multiple Security Filter Chains
 7. Custom UserDetails
 8. Custom AuthenticationProvider
 9. Custom Permission Evaluator
 10. ACL (Access Control List)
-

Module 15: Method Security

1. EnableMethodSecurity
 2. @PreAuthorize
 3. @PostAuthorize
 4. @PreFilter
 5. @PostFilter
 6. SpEL in Security
-

Module 16: Microservices Security

1. API Gateway Authentication
2. JWT Validation at Gateway

3. Service-to-Service Authentication
 4. OAuth2 Resource Server
 5. Token Relay
 6. API Security Best Practices
 7. Spring Cloud Gateway Security
-

Module 17: Banking & Enterprise Security

1. MFA (Multi-Factor Authentication)
 2. OTP Authentication
 3. Account Locking
 4. Password Expiration
 5. Login Attempt Tracking
 6. Audit Logging
 7. Encryption vs Hashing
 8. Secrets Management
 9. Key Rotation
 10. Secure Headers
 11. HSTS
 12. CSP (Content Security Policy)
-

Module 18: Security Testing

1. Spring Security Test
 2. MockMvc Security Tests
 3. @WithMockUser
 4. JWT Testing
 5. Integration Testing
 6. Penetration Testing Basics
-

Module 19: Spring Security Interview Topics

1. Authentication vs Authorization
2. How Spring Security Works Internally
3. Complete Request Flow
4. Security Filter Chain
5. Why OncePerRequestFilter?
6. Why BCrypt?
7. Why JWT?
8. Why Stateless?
9. Why Disable CSRF with JWT?
10. JWT vs Session
11. OAuth2 vs JWT
12. Role vs Authority
13. AuthenticationManager vs AuthenticationProvider
14. UserDetailsService vs UserDetailsManager
15. Principal vs Authentication
16. SecurityContext vs SecurityContextHolder
17. CORS vs CSRF
18. Access Token vs Refresh Token
19. HS256 vs RS256
20. How would you secure a banking application?

Real-Time Project Topics

- Login using JWT
- Refresh Token implementation
- Role-Based Access Control (RBAC)
- Method-Level Security
- API Gateway Authentication

- Secure Microservices
- File Upload Security
- Password Reset using Email
- Forgot Password Flow
- OTP Verification
- Account Locking after Failed Logins
- Audit Logging
- Custom Exception Handling
- Logout with JWT Blacklisting
- Token Refresh Strategy
- API Rate Limiting
- CORS Configuration
- Secure REST APIs
- Swagger Security Integration

Recommended Learning Order

1. Security Fundamentals
2. Spring Security Basics
3. Authentication
4. Authorization
5. Password Security
6. Session Management
7. CSRF
8. JWT
9. Stateless Authentication
10. Filters
11. Exception Handling
12. CORS
13. Method Security

14. OAuth 2.0 & OIDC
15. Advanced Spring Security
16. Microservices Security
17. Banking & Enterprise Security
18. Security Testing
19. Interview Questions
20. Build a complete real-world Spring Security project.